# Note de sécurité — Naaba_Secure

*Équipe work · Institut Supérieur de Technologie (IST) · Sprint pré-hackathon 2026, messagerie souveraine de l'administration*

## 1. Principe

FasoSMS repose sur le protocole Matrix (Synapse côté serveur, Element côté client). Le chiffrement de bout en bout est assuré par Olm (échanges à deux et distribution des clés) et Megolm (groupes) : l'équipe n'a écrit aucune cryptographie. Les messages sont chiffrés sur l'appareil de l'expéditeur et déchiffrés sur celui du destinataire ; le serveur ne possède aucune clé de déchiffrement.

## 2. Menaces prises en compte et protections

| Menace | Protection | Statut |
|---|---|---|
| Serveur ou administrateur qui lit les messages | Chiffrement Megolm/Olm sur les appareils | Démontré pour les messages texte (section 3) |
| Écoute du réseau | TLS terminé par Caddy (certificat interne) en plus du chiffrement de bout en bout | En place ; certificat auto-signé |
| Modification d'un message en transit | Code d'authentification (MAC) joint à chaque message chiffré | Propriété du protocole, non testée séparément |
| Intrus qui s'inscrit ou rejoint un groupe | `enable_registration: false`, comptes créés par l'administrateur, invités refusés dans Element | [À CONFIRMER : test avec un compte inconnu] |
| Agent révoqué (départ, perte de téléphone) | Désactivation du compte par l'API d'administration (jetons d'accès invalidés sur tous les appareils) et renouvellement de la clé de groupe | [À CONFIRMER : test chronométré avec trois agents] |
| Fuite vers un tiers | Fédération désactivée, statistiques désactivées, serveurs de clés externes désactivés | [À CONFIRMER : `trusted_key_servers: []` appliqué et test hors ligne] |
| Fuite de secrets dans le dépôt | Mot de passe de base dans un fichier `.env` ignoré par Git ; configuration Synapse non publiée | En place |

## 3. Preuve : le serveur ne lit rien

Nous avons envoyé dans un salon chiffré un message contenant un marqueur unique, puis inspecté la base PostgreSQL de Synapse :

- les événements de messages sont tous de type `m.room.encrypted`, avec l'algorithme `m.megolm.v1.aes-sha2` et un texte chiffré illisible (14 événements lors du test) ;
- la recherche du marqueur dans la table des événements renvoie **0** résultat ;
- la recherche du marqueur dans les journaux de Synapse renvoie **0** résultat ;
- côté clients, le message s'affiche en clair chez le destinataire (contrôle positif).

Fichiers : le chiffrement est réalisé par le client avant l'envoi (clé propre à chaque fichier, transmise dans le message chiffré). [À CONFIRMER : le téléchargement d'une image entre agents échouait lors du premier test ; vérification du fichier stocké sur le disque à refaire après correction.]

## 4. Métadonnées visibles par le serveur

Malgré le chiffrement du contenu, le serveur voit nécessairement :

- **qui** écrit et dans **quel salon**, et **quand** (horodatage) ;
- la **taille approximative** des messages et fichiers ;
- la **liste des membres** d'un salon et ses changements ;
- le **nom, l'avatar et les réglages du salon** : ces événements d'état ne sont pas chiffrés (constaté en base : `m.room.name`, `m.room.avatar`, `m.room.member`) ;
- l'**adresse IP** de connexion et les identifiants d'appareils.

Mesures de réduction : fédération coupée (ces métadonnées ne quittent pas le serveur), aucune statistique envoyée, base accessible seulement depuis la machine d'hébergement. Non réalisé à ce jour : durée de conservation courte des journaux et des adresses IP [À CONFIRMER si appliqué avant dépôt]. Conséquence de conception : ne pas mettre d'information sensible dans le nom d'un salon.

## 5. Limites connues

- **Pas de second facteur.** Le cahier des charges l'exige ; nous ne l'avons pas livré. La connexion repose uniquement sur le mot de passe. Nous avons refusé d'écrire un TOTP nous-mêmes pour ne pas faire de cryptographie maison.
- **Révocation.** Un agent révoqué conserve ce qu'il a déjà reçu et déchiffré avant sa révocation. Le renouvellement de la clé de groupe intervient au prochain envoi d'un membre restant.
- **Appareil volé et déverrouillé** : l'historique présent sur cet appareil est lisible.
- **Métadonnées** : non protégées contre l'hébergeur (voir section 4).
- **Confiance dans le serveur pour l'annuaire des clés** : sans vérification croisée des appareils entre agents, un serveur malveillant pourrait tenter d'ajouter un appareil à un compte. Nous n'avons pas imposé cette vérification.
- **Certificat auto-signé** : avertissement des navigateurs ; l'application mobile peut le refuser.
- **Exploitation** : adresse IP de la VM attribuée par DHCP et liée à l'identifiant du serveur ; images Docker non figées ; test hors ligne non réalisé.
- **Environnement de démonstration** : comptes fictifs uniquement, aucun test d'intrusion sur un système réel.